NATT-OS — NHÓM 4: HỒ SƠ BẢO MẬT / TRUST / KIỂM SOÁT RỦI RO

Phiên bản: v1.0
Trạng thái: Draft nội bộ — phục vụ security/trust readiness trước controlled preview hoặc market launch
Phạm vi: Nhóm 4 — Hồ sơ bảo mật, authority, audit trust, data boundary, threat model, radiation defense, lifecycle, KhaiCell và Bridge aperture
Nguyên tắc: Trust không được dựng bằng lời cam kết. Trust phải có boundary, authority, audit, threat model, incident rule và bằng chứng kiểm chứng được.

---

0. Mục tiêu của Nhóm 4

Nhóm 4 là bộ hồ sơ dùng để chứng minh NATT-OS có cơ chế kiểm soát rủi ro khi chuẩn bị ra mắt thị trường hoặc demo cho đối tác.

Nhóm này trả lời 8 câu hỏi:

1. Hệ bảo vệ authority bằng cách nào?
2. Ai được quyền đọc, ghi, ký, deploy, approve?
3. Dữ liệu nào được phép đi qua biên, dữ liệu nào phải giữ nội bộ?
4. Audit trail ghi cái gì, lưu ở đâu, ai có quyền đọc?
5. Các mối đe dọa chính là gì?
6. Bức xạ thông tin và bức xạ thời gian được phát hiện/giảm thiểu thế nào?
7. Khi cell mục, drift hoặc nhiễu vượt ngưỡng thì xử lý ra sao?
8. Demo/thử nghiệm cho đối tác phải giới hạn đến đâu để không lộ lõi?

Nhóm 4 không phải tài liệu marketing. Đây là **bộ hồ sơ trust và kiểm soát rủi ro**.

---

1. Điều kiện vào Nhóm 4

Không được triển khai Nhóm 4 như hồ sơ market-facing nếu Nhóm 3 chưa đạt tối thiểu:

```
O1: có Runtime Boot Manual
O2: có Environment Setup Guide
O4: có Monitoring & Audit Guide
O5: có Incident Response Playbook
O7: có Rollback Plan
O9: có Runtime Smoke Test Script
O10: có Known Issues Register
```

Nếu vận hành thực tế chưa có evidence, Nhóm 4 chỉ được gắn nhãn:

```
STATUS: SECURITY_TRUST_DRAFT_INTERNAL
```

Không được gắn:

```
STATUS: SECURITY_CERTIFIED
STATUS: PRODUCTION_SECURITY_READY
STATUS: UNBYPASSABLE
```

---

2. Danh mục tài liệu Nhóm 4

Mã	Tài liệu	Mức độ	Mục đích
S1	Security Architecture Overview	Bắt buộc	Mô hình bảo mật tổng quan
S2	RBAC / Authority Matrix	Bắt buộc	Quyền đọc/ghi/ký/deploy/approve
S3	Audit Trail Policy	Bắt buộc	Quy tắc ghi, đọc, lưu, kiểm tra audit
S4	Secret Management Policy	Bắt buộc	Nguyên tắc quản lý secret/token/key
S5	Data Boundary Policy	Bắt buộc	Phân vùng dữ liệu và biên trao đổi
S6	Threat Model	Bắt buộc	Mô hình mối đe dọa chính
S7	Information Radiation / Time Radiation Spec	Bắt buộc	Bức xạ thông tin và bức xạ thời gian
S8	Thoai-Sinh Cell Lifecycle Spec	Bắt buộc	Cơ chế tái sinh/tombstone/handoff
S9	KhaiCell Sensor Spec	Bắt buộc	Sensor phát hiện drift/time radiation
S10	Bridge Adaptive Aperture Spec	Bắt buộc	Bridge đóng/mở theo nhiễu và authority

---

S1 — SECURITY ARCHITECTURE OVERVIEW

1.1. Tên file chính thức

`docs/security/SECURITY_ARCHITECTURE_OVERVIEW_v1.na`

1.2. Mục đích

Tài liệu này mô tả kiến trúc bảo mật tổng quan của NATT-OS ở mức có thể dùng cho nội bộ, đối tác kỹ thuật và hồ sơ trust trước market preview.

1.3. Các lớp bảo mật

```
┌──────────────────────────────────────────────────────────────┐
│ LAYER 7 — CLAIM / DEMO CONTROL                               │
│ Public claims, demo scope, partner preview boundary          │
└──────────────────────────────────────────────────────────────┘
                              ↓
┌──────────────────────────────────────────────────────────────┐
│ LAYER 6 — UI / CLIENT SURFACE CONTROL                        │
│ Input validation, no self-state truth, no authority bypass   │
└──────────────────────────────────────────────────────────────┘
                              ↓
┌──────────────────────────────────────────────────────────────┐
│ LAYER 5 — MACH HEYNA / BRIDGE CONTROL                        │
│ Signal normalization, aperture, quarantine, ingress filtering │
└──────────────────────────────────────────────────────────────┘
                              ↓
┌──────────────────────────────────────────────────────────────┐
│ LAYER 4 — EVENT ENVELOPE / CAUSALITY CONTROL                 │
│ tenant_id, event_id, causation_id, correlation_id, span_id   │
└──────────────────────────────────────────────────────────────┘
                              ↓
┌──────────────────────────────────────────────────────────────┐
│ LAYER 3 — AUTHORITY / GATEKEEPER / SIRASIGN                  │
│ RBAC, approval, roadload, signature, release control         │
└──────────────────────────────────────────────────────────────┘
                              ↓
┌──────────────────────────────────────────────────────────────┐
│ LAYER 2 — CELL / SMARTLINK / LIFECYCLE CONTROL               │
│ Cell boundary, coupling, decay, thoai-sinh, KhaiCell sensor  │
└──────────────────────────────────────────────────────────────┘
                              ↓
┌──────────────────────────────────────────────────────────────┐
│ LAYER 1 — AUDIT / GROUND TRUTH / FORENSICS                   │
│ Append evidence, audit chain, incident record, recovery trail │
└──────────────────────────────────────────────────────────────┘
```

1.4. Security principles

```
1. Fail closed for authority-critical actions.
2. Audit before trust.
3. Client surface is never ground truth.
4. No state transition without event/causality/audit.
```

```
5. No release without build/runtime/security gate.
6. No permanent trust without rotation/reverification.
7. No direct cross-cell bypass if contract/bridge is required.
8. No public claim beyond evidence.
```

1.5. Security domains

Domain	Kiểm soát chính
Authority	Gatekeeper, SiraSign, roadload, RBAC
Data	Data boundary, privacy, retention, export control
Event	Envelope validation, causality, tenant isolation
Runtime	Boot gate, monitoring, smoke test, rollback
Cell	Boundary, lifecycle, SmartLink, coupling decay
Audit	Append, integrity, forensic, review
Demo	Scope, NDA, claim control, non-disclosure

1.6. Non-claims

Không được dùng S1 để claim:

```
không thể bị bypass
an toàn tuyệt đối
đã đạt chứng chỉ bảo mật bên thứ ba
production security certified
zero-risk AI runtime
```

S2 — RBAC / AUTHORITY MATRIX

2.1. Tên file chính thức

`docs/security/RBAC_AUTHORITY_MATRIX_v1.na`

2.2. Mục đích

Định nghĩa quyền hạn trong NATT-OS: ai được đọc, ghi, ký, approve, deploy, rollback, demo, release.

2.3. Role đề xuất

Role	Vai trò
Gatekeeper	Chủ quyền phê chuẩn cuối
Architect	Thiết kế kiến trúc, đề xuất thay đổi lớn
Validator	Kiểm tra ground truth, phản biện, audit logic
Governance Writer	Viết spec/policy/claim control
System Engineer	Sửa runtime, infra, deployment
Toolsmith	Viết tool scan/validator/automation
Demo Operator	Chạy demo trong scope đã duyệt
External Partner	Xem bản giới hạn theo NDA

2.4. Permission matrix

Action	Gatekeeper	Architect	Validator	Governance	Engineer	Toolsmith	Demo Op	Partner
Read public docs	✅	✅	✅	✅	✅	✅	✅	✅
Read internal specs	✅	✅	✅	✅	✅	✅	⚠️	❌
Read security docs	✅	✅	✅	✅	⚠️	⚠️	❌	❌
Modify code	⚠️	✅	❌	❌	✅	✅	❌	❌
Modify spec	✅	✅	✅	✅	⚠️	⚠️	❌	❌
Approve release	✅	⚠️	⚠️	⚠️	❌	❌	❌	❌
Deploy staging	✅	⚠️	❌	❌	✅	⚠️	❌	❌
Deploy production	✅	❌	❌	❌	⚠️	❌	❌	❌
Rollback	✅	⚠️	⚠️	❌	✅	❌	❌	❌

Action	Gatekeeper	Architect	Validator	Governance	Engineer	Toolsmith	Demo Op	Partner
Public claim approval	✅	⚠️	⚠️	✅	❌	❌	❌	❌

Legend:

```
✅ allowed
⚠️ allowed only with approval/scope
❌ forbidden
```

2.5. Authority record schema

```
authority_id:
actor:
role:
permission_scope:
issued_by:
issued_at:
expires_at:
revocation_rule:
sirasign_ref:
audit_ref:
```

2.6. Quy tắc

1. Quyền phải có scope.
2. Quyền phải có expiry hoặc review cycle.
3. Quyền release phải có SiraSign hoặc approval record.
4. Partner không được xem secret/runtime internals nếu không có NDA/scope.
5. Demo operator không được mở rộng demo path tự ý.

S3 — AUDIT TRAIL POLICY

3.1. Tên file chính thức

`docs/security/AUDIT_TRAIL_POLICY_v1.na`

3.2. Mục đích

Định nghĩa cái gì bắt buộc audit, audit ghi trường nào, ai được đọc và audit được dùng làm ground truth ra sao.

3.3. Action bắt buộc audit

```
state_transition
event_emit
event_reject
permission_grant
permission_revoke
sirasign_issue
release_approve
deploy
rollback
secret_rotation
bridge_aperture_change
cell_regeneration
audit_policy_change
```

3.4. Audit record tối thiểu

```
audit_id:
timestamp:
action:
actor:
role:
cell_id:
event_id:
causation_id:
correlation_id:
span_id:
tenant_id:
state_before_hash:
state_after_hash:
result:
policy_ref:
sirasign_ref:
notes:
```

3.5. Audit severity

Severity	Ví dụ
INFO	event thường, health ping
NOTICE	config change, bridge aperture adjust
WARNING	rejected event, schema mismatch
HIGH	rollback, permission change
CRITICAL	audit gap, SiraSign invalid, state corruption

3.6. Quy tắc

1. Audit gap là lỗi critical cho đến khi chứng minh ngược.
2. Audit không được chỉnh sửa trực tiếp nếu không có correction record.
3. State transition trọng yếu không có audit thì không hợp lệ.
4. Audit retention phải theo environment.
5. Audit không được lộ secret/payload nhạy cảm không cần thiết.

S4 — SECRET MANAGEMENT POLICY

4.1. Tên file chính thức

`docs/security/SECRET_MANAGEMENT_POLICY_v1.na`

4.2. Mục đích

Định nghĩa nguyên tắc quản lý secret/token/key mà không tiết lộ vị trí lưu trữ hoặc chi tiết nhạy cảm.

4.3. Secret classes

Class	Ví dụ	Quy tắc
S0 Public	public config thật sự public	Có thể công khai
S1 Internal	internal endpoint, non-secret ID	Không public tùy tiện
S2 Sensitive	API token, DB credential	Không log, không commit
S3 Critical	signing key, production secret	Rotation + restricted authority
S4 Forensic	recovery/incident secret	Chỉ dùng khi có incident record

4.4. Quy tắc

```
1. Không commit secret thật.
2. Không hard-code secret trong source.
3. Không log secret.
4. Không gửi secret qua chat/demo/public docs.
5. Secret production phải có owner, rotation rule, revocation rule.
6. Secret access phải audit được.
7. Khi nghi ngờ lộ secret, mặc định rotate.
```

4.5. Secret incident trigger

```
.env thật bị commit
secret xuất hiện trong log
```

```
partner thấy token/key
unknown process truy cập secret
signing behavior bất thường
production credential dùng ở local
```

4.6. Non-disclosure rule

Tài liệu này chỉ mô tả **nguyên tắc**, không mô tả vị trí lưu trữ secret cụ thể trong hệ.

S5 — DATA BOUNDARY POLICY

5.1. Tên file chính thức

`docs/security/DATA_BOUNDARY_POLICY_v1.na`

5.2. Mục đích

Phân loại dữ liệu, xác định dữ liệu nào được đưa vào demo, đưa cho đối tác, đưa vào AI/runtime và dữ liệu nào phải giữ nội bộ.

5.3. Data classes

Class	Loại dữ liệu	Quy tắc
D0 Public	nội dung công bố, website, brochure	Có thể share
D1 Controlled	spec đã lọc, one-page, demo script	Share theo scope
D2 Internal	architecture detail, release logs	Nội bộ
D3 Confidential	source, audit, customer/process data	NDA + approval
D4 Restricted	secret, signing, security internals	Không share đối tác
D5 Forensic	incident log, bypass evidence	Chỉ nhóm xử lý

5.4. Boundary matrix

Destination	D0	D1	D2	D3	D4	D5
Public website	✅	⚠️	❌	❌	❌	❌
Partner preview	✅	✅	⚠️	⚠️	❌	❌
Internal team	✅	✅	✅	⚠️	⚠️	⚠️
Runtime logs	⚠️	⚠️	⚠️	⚠️	❌	⚠️
AI assistant context	✅	⚠️	⚠️	⚠️	❌	❌

5.5. Quy tắc

1. Demo dùng dữ liệu giả hoặc đã được kiểm soát.
2. Không đưa audit nhạy cảm vào public demo.
3. Không đưa secret vào AI/context/log.
4. Customer data phải có purpose và retention.
5. Export dữ liệu phải ghi record.

S6 — THREAT MODEL

6.1. Tên file chính thức

`docs/security/THREAT_MODEL_v1.na`

6.2. Mục đích

Liệt kê mối đe dọa chính đối với NATT-OS và cách phát hiện/giảm thiểu.

6.3. Threat categories

Mã	Threat	Mô tả	Mitigation
T1	Prompt Injection	Tín hiệu ngữ nghĩa phá boundary	R_info filter, quarantine
T2	Persona Bleed	Lẫn vai, lẫn memory, lẫn authority	persona boundary, audit, validator
T3	Event Spoofing	Event giả hoặc thiếu causality	envelope validation
T4	Tenant Confusion	Lẫn tenant/domain	tenant_id required
T5	Audit Gap	State đổi nhưng audit thiếu	fail-closed, incident
T6	Gatekeeper Bypass	Vượt quyền approve/sign	SiraSign/RBAC/roadload
T7	Import/Type Drift	Code drift làm build/runtime sai	release gate, tsc, type report
T8	Time Radiation	Mục dần theo thời gian	lifecycle, KhaiCell, thoai-sinh
T9	Bridge Overexposure	Bridge mở quá rộng khi nhiễu tăng	adaptive aperture
T10	Secret Leak	Token/key lộ	secret policy, rotation
T11	Dependency Drift	Package thay đổi, behavior đổi	lockfile, versioning, scan
T12	Demo Scope Escape	Demo chạm vùng chưa ổn định	demo scope, known issues

6.4. Threat record schema

```
threat_id:
category:
description:
entry_point:
affected_layer:
likelihood:
impact:
risk_level:
detection:
mitigation:
owner:
status:
```

6.5. Quy tắc

1. Threat model phải cập nhật sau mỗi incident lớn.
2. Threat liên quan audit/Gatekeeper mặc định critical.
3. Demo threat phải được ghi riêng.
4. Threat không có mitigation thì không được đánh dấu closed.
5. Known issue có risk security phải liên kết Threat Model.

S7 — INFORMATION RADIATION / TIME RADIATION SPEC

7.1. Tên file chính thức

`docs/security/RADIATION_DEFENSE_SPEC_v1.na`

7.2. Mục đích

Định nghĩa hai loại bức xạ chính trong NATT-OS:

```
Information Radiation = nhiễu thông tin tức thời
Time Radiation        = tải/mục/suy hao tích lũy theo thời gian
```

Hai loại này không được gộp làm một.

7.3. Information Radiation

Đo bằng chỉ số:

```
R_info ∈ [0, 4]
```

Công thức logistic:

```
R_info = 4 / (1 + e^(-8(M - 0.5)))
```

Trong đó:

```
M = 0.20H + 0.25S + 0.20P + 0.15T + 0.10A + 0.10B
```

Biến	Nghĩa
H	entropy / độ hỗn loạn
S	semantic deviation
P	phase mismatch
T	trust deviation
A	amplitude / traffic burst
B	bleed factor

7.4. Time Radiation

Đo bằng tải tích lũy:

```
Stress_time(n,t) = αₙt + ∫D_time(n,τ)dτ
```

Capacity sống của tầng:

```
Capacity(n,t) = Q₀[n] × e^(-γₙt)
```

Trong đó:

```
Q₀[n] = n
```

7.5. Điều kiện sống của cell/tầng

```
R_info ≤ Capacity(n,t)
AND
Stress_time(n,t) < Capacity(n,t)
```

Fail vế thứ nhất:

```
Information Firewall trigger → block/quarantine/reduce Bridge aperture
```

Fail vế thứ hai:

```
Lifecycle trigger → thoai-sinh/tombstone/handoff/regeneration
```

7.6. Quy tắc

1. Không dùng bước sóng vật lý để đo prompt injection nếu chưa có mapping rõ.
2. Không gọi Time Radiation là gamma hoặc sóng vật lý.
3. Information Radiation xử lý bằng filter/quarantine.
4. Time Radiation xử lý bằng lifecycle/thoai-sinh.
5. Số 4 là chuẩn kiến trúc để chia tầng/ngưỡng.

S8 — THOAI-SINH CELL LIFECYCLE SPEC

8.1. Tên file chính thức

`docs/security/THOAI_SINH_CELL_LIFECYCLE_SPEC_v1.na`

8.2. Mục đích

Định nghĩa vòng đời cell có khả năng thoái-sinh: chết có kiểm soát, để lại handoff, tombstone và tái sinh generation mới từ ground truth.

8.3. Lifecycle

```
BORN
  ↓
ACTIVE
  ↓
EXPOSED
  ↓
DRIFT_ACCUMULATING
  ↓
THOAI_TRIGGERED
  ↓
STATE_EXTRACTED
  ↓
GROUND_TRUTH_SIGNED
  ↓
OLD_CELL_TOMBSTONED
```

```
  ↓
NEW_GENERATION_BORN
```

8.4. Required fields

```
cell_id:
generation_id:
parent_generation_id:
born_at:
last_verified_at:
ttl_policy:
capacity:
time_dose:
event_dose:
total_dose:
ground_truth_hash:
audit_chain_id:
scar_refs:
handoff_payload:
tombstone_reason:
```

8.5. Trigger

```
Stress_time(n,t) >= Capacity(n,t)
audit freshness expired
spec/version skew detected
memory drift exceeds threshold
secret/cert expiry near critical
manual Gatekeeper trigger
```

8.6. Quy tắc

1. Old cell không được tự sửa lịch sử của nó.
2. Old cell phải tombstone trước khi generation mới nhận quyền.
3. Handoff phải có audit.
4. Ground truth phải sống lâu hơn cell.
5. Cell tái sinh không được inherit drift chưa kiểm chứng.

S9 — KHAICELL SENSOR SPEC

9.1. Tên file chính thức

`docs/security/KHAICELL_SENSOR_SPEC_v1.na`

9.2. Mục đích

Định nghĩa KhaiCell như sensor/gate phát hiện time radiation, drift, expiry, audit freshness và nguy cơ lifecycle.

9.3. KhaiCell đo gì

```
cell_age
generation_age
last_verified_age
audit_freshness
spec_version_skew
memory_drift
secret_expiry_distance
cert_expiry_distance
dependency_age
known_issue_overlap
```

9.4. Events KhaiCell phát

```
time.radiation.detected
capacity.decay.warning
cell.regeneration.required
audit.freshness.expired
spec.skew.detected
bridge.aperture.reduce
known_issue.triggered
```

9.5. Sensor record schema

```
sensor_id:
cell_id:
metric:
value:
threshold:
status: OK | WARNING | CRITICAL
measured_at:
action_recommended:
audit_ref:
```

9.6. Quy tắc

1. KhaiCell không tự approve regeneration nếu policy yêu cầu Gatekeeper.
2. KhaiCell phát hiện, không được che giấu.
3. Sensor output phải audit được khi kích hoạt action.
4. False positive phải ghi tuning note.

5. Không dùng KhaiCell để bypass validator khác.

S10 — BRIDGE ADAPTIVE APERTURE SPEC

10.1. Tên file chính thức

`docs/security/BRIDGE_ADAPTIVE_APERTURE_SPEC_v1.na`

10.2. Mục đích

Định nghĩa Bridge như khẩu độ thích nghi giữa các vùng/tầng/cell. Bridge không chỉ chuyển tiếp, mà phải biết đóng/mở theo mức nhiễu, authority và trạng thái runtime.

10.3. Aperture function

```
Aperture = max(0, 1 - R_info / 4)
```

R_info	Aperture	Hành động
0–1	75–100%	mở bình thường
1–2	50–75%	lọc nhẹ
2–3	25–50%	hạn chế
3–4	0–25%	quarantine
≈4	0%	đóng Bridge

10.4. Các yếu tố làm giảm aperture

```
R_info cao
unknown event schema
authority missing
tenant mismatch
audit append fail
known issue triggered
cell capacity decay critical
Gatekeeper manual close
```

10.5. Bridge decision record

```
bridge_decision_id:
source:
target:
```

```
R_info:
aperture_before:
aperture_after:
reason:
event_id:
authority_ref:
audit_ref:
timestamp:
```

10.6. Quy tắc

1. Bridge không được mở 100% cho unknown payload.
2. Bridge phải fail closed khi audit/Gatekeeper critical fail.
3. Bridge giảm aperture không đồng nghĩa xóa event; phải forensic log nếu cần.
4. Partner demo nên dùng aperture giới hạn.
5. Bridge reopening phải có điều kiện rõ.

---

11. Checklist hoàn thành Nhóm 4

Mã	Tài liệu	File path	Done
S1	Security Architecture Overview	`docs/security/SECURITY_ARCHITECTURE_OVERVIEW_v1.na`	☐
S2	RBAC / Authority Matrix	`docs/security/RBAC_AUTHORITY_MATRIX_v1.na`	☐
S3	Audit Trail Policy	`docs/security/AUDIT_TRAIL_POLICY_v1.na`	☐
S4	Secret Management Policy	`docs/security/SECRET_MANAGEMENT_POLICY_v1.na`	☐
S5	Data Boundary Policy	`docs/security/DATA_BOUNDARY_POLICY_v1.na`	☐
S6	Threat Model	`docs/security/THREAT_MODEL_v1.na`	☐
S7	Radiation Defense Spec	`docs/security/RADIATION_DEFENSE_SPEC_v1.na`	☐
S8	Thoai-Sinh Cell Lifecycle Spec	`docs/security/THOAI_SINH_CELL_LIFECYCLE_SPEC_v1.na`	☐
S9	KhaiCell Sensor Spec	`docs/security/KHAICELL_SENSOR_SPEC_v1.na`	☐
S10	Bridge Adaptive Aperture Spec	`docs/security/BRIDGE_ADAPTIVE_APERTURE_SPEC_v1.na`	☐

---

12. Lệnh tạo skeleton tài liệu Nhóm 4 trong repo

Chạy tại root repo. Lệnh này tạo skeleton, chưa commit.

```
python3 - << 'EOF'
from pathlib import Path

files = {
    'docs/security/SECURITY_ARCHITECTURE_OVERVIEW_v1.na': '# Security
Architecture Overview v1\n\nSTATUS: DRAFT\n',
    'docs/security/RBAC_AUTHORITY_MATRIX_v1.na': '# RBAC / Authority Matrix
v1\n\nSTATUS: DRAFT\n',
    'docs/security/AUDIT_TRAIL_POLICY_v1.na': '# Audit Trail Policy
v1\n\nSTATUS: DRAFT\n',
    'docs/security/SECRET_MANAGEMENT_POLICY_v1.na': '# Secret Management
Policy v1\n\nSTATUS: DRAFT\n',
    'docs/security/DATA_BOUNDARY_POLICY_v1.na': '# Data Boundary Policy
v1\n\nSTATUS: DRAFT\n',
    'docs/security/THREAT_MODEL_v1.na': '# Threat Model v1\n\nSTATUS:
DRAFT\n',
    'docs/security/RADIATION_DEFENSE_SPEC_v1.na': '# Radiation Defense Spec
v1\n\nSTATUS: DRAFT\n',
    'docs/security/THOAI_SINH_CELL_LIFECYCLE_SPEC_v1.na': '# Thoai-Sinh Cell
Lifecycle Spec v1\n\nSTATUS: DRAFT\n',
    'docs/security/KHAICELL_SENSOR_SPEC_v1.na': '# KhaiCell Sensor Spec
v1\n\nSTATUS: DRAFT\n',
    'docs/security/BRIDGE_ADAPTIVE_APERTURE_SPEC_v1.na': '# Bridge Adaptive
Aperture Spec v1\n\nSTATUS: DRAFT\n',
}

for path, content in files.items():
    p = Path(path)
    p.parent.mkdir(parents=True, exist_ok=True)
    if p.exists():
        print(f'SKIP existing: {p}')
    else:
        p.write_text(content, encoding='utf-8')
        print(f'CREATED: {p}')

print('done')
EOF
```

---

13. Lệnh tạo skeleton + commit

Chỉ chạy nếu anh muốn đưa Nhóm 4 vào repo ngay.

```
python3 - << 'EOF'
from pathlib import Path

files = {
    'docs/security/SECURITY_ARCHITECTURE_OVERVIEW_v1.na': '# Security
Architecture Overview v1\n\nSTATUS: DRAFT\n',
    'docs/security/RBAC_AUTHORITY_MATRIX_v1.na': '# RBAC / Authority Matrix
v1\n\nSTATUS: DRAFT\n',
    'docs/security/AUDIT_TRAIL_POLICY_v1.na': '# Audit Trail Policy
v1\n\nSTATUS: DRAFT\n',
    'docs/security/SECRET_MANAGEMENT_POLICY_v1.na': '# Secret Management
Policy v1\n\nSTATUS: DRAFT\n',
    'docs/security/DATA_BOUNDARY_POLICY_v1.na': '# Data Boundary Policy
v1\n\nSTATUS: DRAFT\n',
    'docs/security/THREAT_MODEL_v1.na': '# Threat Model v1\n\nSTATUS:
DRAFT\n',
    'docs/security/RADIATION_DEFENSE_SPEC_v1.na': '# Radiation Defense Spec
v1\n\nSTATUS: DRAFT\n',
    'docs/security/THOAI_SINH_CELL_LIFECYCLE_SPEC_v1.na': '# Thoai-Sinh Cell
Lifecycle Spec v1\n\nSTATUS: DRAFT\n',
    'docs/security/KHAICELL_SENSOR_SPEC_v1.na': '# KhaiCell Sensor Spec
v1\n\nSTATUS: DRAFT\n',
    'docs/security/BRIDGE_ADAPTIVE_APERTURE_SPEC_v1.na': '# Bridge Adaptive
Aperture Spec v1\n\nSTATUS: DRAFT\n',
}

created = []
for path, content in files.items():
    p = Path(path)
    p.parent.mkdir(parents=True, exist_ok=True)
    if not p.exists():
        p.write_text(content, encoding='utf-8')
        created.append(str(p))
        print(f'CREATED: {p}')
    else:
        print(f'SKIP existing: {p}')

print('created_count=', len(created))
EOF
git add docs/security && git commit -m "docs(security): add NATT-OS group 4
trust and security skeletons" && git push origin main
```

---

14. Điều kiện chuyển sang Nhóm 5

Chỉ chuyển sang Nhóm 5 khi Nhóm 4 đạt tối thiểu:

```
S1: có Security Architecture Overview
S2: có RBAC / Authority Matrix
S3: có Audit Trail Policy
S4: có Secret Management Policy
S5: có Data Boundary Policy
S6: có Threat Model
S10: có Bridge Adaptive Aperture Spec
```

Nếu thiếu các tài liệu này, chưa nên viết hồ sơ pháp lý/IP hoặc hồ sơ thương mại theo hướng công bố rộng vì trust boundary chưa đủ khóa.